Monthly Intelligence Dispatch

January 2020

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- The Silence threat group continues its global expansion by multiplying their attacks outside Russia. Group-IB's Threat Intelligence team discovered traces of Silence attacks on banks in Africa.
- Two major finds were made on Joker's Stash: over 92,000 pieces of textual bank card data of **Malaysian banks** and a **dump database** with 30 million cards of customers of Wawa, a US chain of convenience stores and gas stations, were put up for sale in January.
- The Iran-linked group APT34 is targeting a US research company — likely Westat — that provides services to businesses and government agencies.
- The China-linked cyberespionage APT group **Bronze President** is targeting political and law enforcement organizations and NGOs in South-East Asia.

Our forecast is coming true: Silence continues its worldwide expansion by multiplying their attacks outside Russia. In late 2019, Group-IB's Threat Intelligence team discovered traces of Silence attacks on banks in Africa.

As early as the summer of 2019, Group-IB specialists observed attacks on banks in Chile, Costa Rica, Ghana, Bulgaria, and Bangladesh. All the banks were promptly notified of the threat, but in some cases the victims were unable to properly respond to it. This is what happened with the Bangladeshi bank Dutch-Bangla. After several thefts, six Ukrainian citizens that Silence had hired to withdraw money were arrested. Our specialists analyzed the attacks and concluded that they involved a unique new tool named EDA as well as xfs-disp.exe, a banking Trojan that had earlier been used by Silence in their attack on the Russian bank IT Bank. The initial infection is achieved through ServHelper backdoor. Some sources say the initial attacks had been carried out by a different hacker group, TA505, which then sold access to banks to Silence. At the moment, it is not possible to confirm whether TA505 was involved in the attacks.

According to Group-IB's data, Silence is in the top five most relevant threats to the financial sector: Cobalt, Silence, and MoneyTaker (Russia), Lazarus (North Korea), and SilentCards (new group from Kenya). In Russia, the damage from targeted attacks of financially motivated threat groups has fallen almost 14-fold. One of the reasons for that is that financially motivated hackers shifted their focus from the Russian banking sector to banks worldwide.

APT34	The Iran-linked group APT34 is targeting a US research company — likely Westat — that provides services to businesses and government agencies, Intezer experts say. The attackers used a phishing document masquerading as a survey for employees at the US government contractor Westat. The recent campaign appears similar to the one observed by FireEye in July 2019, when hackers were posing as a researcher from Cambridge to infect victims with three new malicious programs. The experts believe APT34 (also known as OilRig and Helix Kitten) is behind the attack. APT34 is an Iran-linked APT group. It has been around since about 2014 and mainly targets organizations in the financial, government, energy, telecommunications, and chemical sectors in the United States and the Middle East.
PupyRAT	Iran-linked APT groups used a remote access Trojan (RAT) called PupyRAT in their recent attacks on the European energy sector, experts at Recorded Future reported. The experts discovered malicious traffic between installed PupyRAT and the threat actors' command and control (C&C) server; the communication took place between November 2019 and January 2020. The PupyRAT backdoor is an open-source malicious program available on GitHub. It was used in previous campaigns linked to Iranian ATP groups such as APT33 (also known as Elfin, Magic Hound, and HOLMIUM), COBALT GYPSY, and APT34.

Bronze President

The China-linked cyberespionage APT group **Bronze President** is targeting political and law enforcement organizations and NGOs in South-East Asia, experts at Secureworks warn. The Chinese threat group has been active since at least 2014 and has used both their own and publicly available tools in their attacks. Other tools, such as PlugX, are well known and have been involved in multiple campaigns linked to Chinese APTs.

APT40

Another China-linked threat group, APT40, hides behind 13 front companies, a group of anonymous security analysts called Intrusion Truth said. According to the researchers, APT40 uses a dozen front companies on Hainan island to recruit new hackers. Intrusion Truth has already linked other APTs to particular regions in China: APT3 (Guangdong), APT10 (Tianjin), and APT17 (Jinan). Even though Intrusion Truth did not link the Hainan group directly to APT40 (also known as TEMP.Periscope, TEMP.Jumper, and Leviathan), FireEye and Kaspersky did.

Shlayer

According to Kaspersky Lab, the **Shlayer** Trojan became the most common threat on the macOS platform both worldwide (10% of users) and in Russia (12% of users). Shlayer, which specializes in installing advertising software, has been the most common threat on the macOS platform for close to two years: the security researchers obtained the first samples of the malware family as early as February 2018; nearly 32,000 samples of the Trojan have since been collected, with 143 C&C server domains identified. The Trojan was distributed disguised as Adobe Flash Player updates.

Joker's Stash

On January 7, 2020, Group-IB's monitoring of card shops revealed a new database on Joker's Stash, a card shop. The database is called NO-CVV-MIX and contains over 92,000 "CCs" (textual bank card data) without CVV/CVC information. Over 99.7% of the cards from this database belong to Malasian banks. The card shop publishes databases that lack CVV/CVC information very rarely (the last such case was on May 22, 2019), which means that the new database is quite unique for the resource and the source of the compromise might differ from previous cases. Threat actors can use cards without CVV/CVC to purchase goods or services on websites that accept payments without that information. At the moment, the source of the compromise of the cards from the NO-CVV-MIX database has not been established.

Joker's Stash

Later, on January 27, 2020, the first part of a new dump database called BIGBADABOOM-III (BBB3 BREACH) appeared on the same resource, Joker's Stash, whose owner said that the full database contained over 30 million cards. As at late January, a total of four databases from the BBB3 BREACH leak had been published, with 3,569,558 cards available for purchase. The number of cards, the sale of magnetic stripe data (dumps) without PIN codes, and the fact that the cards' breakdown by banks is relatively even suggest that the source of the compromise was a network of trojanised POS terminals. Group-IB specialists analyzed bank cards from the BBB3 BREACH and established that some of the cards from the BIGBADABOOM-III databases seemed to have been compromised in Wawa, a US chain of convenience stores and gas stations located along the East Coast of the United States. Noteworthy is the fact that on December 19, 2019, Wawa published an alert on their official website saying the payment systems at all their locations had been hacked (https://www.wawa.com/alerts/data-security). On January 29, this alert was updated with a message saying that the breached bank card data had been put up for sale on an underground resource, which was not mentioned.

kalashnikov	A user with the nickname kalashnikov made a post on Exploit.in, an underground forum, about renting out phishing pages. Depending on the country, the user offered pages mimicking a dozen major UK and Italian banks as well as Microsoft Office 365, Hotmail, and Live services. The developer noted that an admin panel can be used for real-time analysis of collected information to log in to accounts and make money transactions. It should be noted that a user with the nickname Profitcoinn featured as a buyer in multiple topics related to the sale of various malware on Exploit.in, in particular KPOT stealer, Amadey loader, and various dumps and data leaks.
pihte	A user with the nickname pihte made a post on Exploit.in about selling a rootkit for Linux OS. The malware is designed to hide network activity, processes, process hierarchy, and CPU usage as well as to conceal files and change their contents. The author noted that the code of the malware was covered with autotests. They also mentioned that they used the malware themselves only. The threat actor specified that the exploit worked on Linux only, but that it could be modified for other Unix-like systems, including old versions (BSD/ AIX / Solaris) if necessary. The price for the malware is $10,000.
Shitrix	The Citrix NetScaler CVE-2019-19781 vulnerability (also known as Shitrix and Citrixmash) enables an unauthorized external threat actor to execute arbitrary code on Citrix servers. The PoC code is publicly available on GitHub. At the time of writing, Metasploit and nmap vulnerability scanners have issued relevant modules that take this vulnerability into account. Many organizations note a high number of attempts to exploit this vulnerability. This topic is also popular in the underground community, including the development and sale of malware for this vulnerability.

Arrests and sentences

Night Fury

Together with INTERPOL and Group-IB, the Indonesian cyberpolice announced that members of a cybergang that used JavaScript sniffers (a popular type of malicious code) to infect hundreds of online stores in Australia, Brazil, the UK, Germany, Indonesia, the United States, and other countries had been arrested in Indonesia. The criminals stole buyers' bank card data and used it to buy gadgets and luxury items. The takedown of the group was the first operation against JS sniffer operators in the Asia-Pacific (APAC) region. The joint operation, called Night Fury, between the Indonesian cyberpolice, INTERPOL's ASEAN Cyber Capability Desk (ASEAN Desk) and Group-IB's Investigation Department took place in December 2019. Three Indonesian residents aged between 23 and 35 were arrested as a result. All of them were charged with theft of electronic data using GetBilling JavaScript sniffer family. The operation continues in five APAC regions. The malware family was first described in Group-IB's report Crime without punishment, which was released in April 2019. JavaScript sniffers are a popular type of malware, which is used for attacks on online stores to steal buyers' personal and payment data, such as bank card numbers, names, addresses, logins, phone numbers, and user data from payment systems. Group-IB's Threat Intelligence specialists have been tracking the GetBilling JS sniffer family since 2018. Analysis of infrastructure that had been controlled by the arrested GetBilling operators revealed that they managed to infect nearly 200 websites in Indonesia, Australia, Europe, the United States, Latin America, and several other countries. The victims included Russian and Ukrainian Internet users who made payments on online stores that were infected with sniffers. According to preliminary estimates, the threat actors collected over 1,000 unique cards and passwords for buyers' accounts from infected websites around the world per week.

Arrests and sentences

Burkov	Aleksey Burkov, a 29-year-old Russian citizen pleaded guilty to creating two resources that helped carders steal over $20 million. According to the US Department of Justice, Burkov ran a website called Cardplanet for several years. The website sold card data for anywhere from $2.50 to $60 apiece (the cost depended on the type of card, country of origin, availability of the name and address of the card holder, as well as other identification information). In total, over 150,000 payment cards were put up for sale on Cardplanet, tens of thousands of which belonged to American users. The sale of cards through Cardplanet led to fraudulent purchases and the damage among US users alone amounted to more than $ 20 million. Burkov was extradited to the United States from Israel in the fall of 2019. He was detained at Ben Gurion Airport back in 2015 at the request of the US authorities. The Russian authorities tried to exchange Alexei Burkov for Israeli citizen Naamu Issahar, who was sentenced in Russia to seven and a half years in prison for allegedly smuggling drugs, but when nothing came of it and the hacker was still handed over to the United States. The Russian embassy in Washington sent a note of protest to the US State Department.
WeLeakInfo.com	In January 2020, a joint operation by the FBI and authorities from Northern Ireland, the Netherlands, Germany, and the UK resulted in the takedown of WeLeakInfo.com. For more than three years, the service sold access to the data of over 12.5 billion accounts collected from 10,000 different data leaks. The website provided access to people's cleartext passwords for as little as $2 per day. The resource was popular and well-known in the black market. Hackers would buy access to the site and then search for the name, email, or userame of a person they wanted to hack. The site would return results about all the data breaches the user's data was included in, including cleartext passwords if available. Hackers would then use these passwords against the user's various profiles hoping that their target reused passwords on other websites.

Forecasts and warnings

- Our forecast is not optimistic: the Russian speaking threat groups Silence, MoneyTaker, and Cobalt are likely to continue to expand their geographical scope by increasing the number of their attacks outside Russia. The groups will launch attacks on card processing systems and use Trojans for ATMs to withdraw money.
- The appearance of the new database NO-CVV-MIX on Joker's Stash means that threat actors can now use cards without CVV/CVC to purchase goods and services on websites that accept payments without that information.
- As of January 14, 2020 Microsoft officially stopped providing free security updates for Windows 7 and ended support for Windows Server 2008 and Windows Server 2008 R2. These server operating systems are still used in organizations, often as Active Directory controllers. They must be updated to 2012R2 (support ends in 2023) or straight to the 2016\19 versions (support ends in 2027 and 2029). The absence of updates for Windows 7 is critical primarily for financial organizations and corporations rather than regular users. Ordinary users can easily migrate to newer operating system versions, while the corporate sector, where older versions are often used for device compatibility, such as ATMs, POS terminals, cash registers, industrial computers, etc. will face a serious problem. Operating system updates are critical for them and will require updating hardware.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com